TAYLOR'S UNIVERSITY

TECHNICAL REPORT

RiskPilot AI SOC Triage

Technical report for Agentic Cyber Defence

A historical flow investigation prototype with evidence checks and analyst control.

Prepared by

Wong Li En
Tian Xinyu
Wong Chin Wen

Competition

HackAI 2026
GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon

Report date

24 October 2026

Project conclusion

RiskPilot AI provides a working investigation workflow for PortScan, DoS and suspected BruteForce. Software and evidence checks pass, but external testing shows weak detector generalisation and an AI tendency to defer judgment. The prototype supports analyst investigation; it does not establish reliable autonomous attack detection or response.

Project Overview

RiskPilot AI is the project name used in this report. The implementation is maintained in the SOC-Triage repository and displayed as SOC Desk. It turns historical network-flow records into rule alerts, groups them into cases and lets an analyst inspect evidence before requesting an AI assessment. The AI can select four read-only tools. The backend checks the resulting proposal, and a human records the decision.

The current bundle contains 9 cases, 158 alerts and 948 sampled flows, represented by 1,106 traceable timeline events. The displayed attack scope is PortScan, DoS and BruteForce. Benign is an offline evaluation label, not an attack rule and not an automatic safe conclusion. DDoS compatibility remains in defensive tests but is outside the current demonstration queue.

The strongest demonstrated result is a controlled, auditable workflow. All 254 automated tests and 21 synthetic safety scenarios passed. However, the current rules missed 73 attack-labelled minute groups in development data and generalised poorly to a separate source. In a five-case external AI diagnostic, every verdict was Needs Review. These are different measurements and must not be combined into an accuracy score.

1 Problem and User

1 1 Analyst workload

SOC analysts must decide whether an alert needs investigation and which records support that decision. Alahmadi et al. (2022) found that perceived false positives often involved legitimate activity triggering a real alarm. Their work also describes the burden of manual validation. This motivates evidence organisation and clear uncertainty rather than automatic dismissal [2].

1 2 Intended user and task

The intended users are Tier 1 and Tier 2 analysts reviewing a suspected incident. They need to understand what triggered a case, see its timing, inspect supporting records, assess the AI explanation and record their own decisions. The prototype replays historical data; it is not a production sensor, live network monitor or endpoint response platform.

1 3 Competition fit

The Agentic Cyber Defence brief asks for a working end-to-end defensive agent, visible tool choices and evidence, human approval before consequential actions, an activity record and limitations. Its SOC triage direction specifically includes alert grouping, incident timelines and next investigation steps [1]. This report follows the six requested demonstration areas and distinguishes implemented behaviour from unproven operational value.

2 Inputs and Evidence

2 1 Data and scoring boundaries

Development uses the CIC-IDS2017 GeneratedLabelledFlows archive, specifically the Monday, Tuesday, Wednesday and Friday afternoon PortScan CSVs. The official dataset contains labelled network flows derived from captured traffic [3]. Labels are retained for offline evaluation and withheld from the model-facing tool schemas. They do not determine which rule fires or how alerts are grouped.

Each detection unit is an ordered source IP, destination IP and calendar minute within one source file. A CSV row counts as one flow record. Forward and backward packet counts are summed. Source-file boundaries and communication direction remain separate. The data clock is displayed as dataset time because the original timestamps do not independently establish UTC.

2 2 Prototype detection rules

Rule	Current trigger
PortScan	At least 100 flows and 100 destination ports, plus either source ports at least twice destination ports, or at least 250 destination ports and 2 source ports.
DoS	At least 1,000 flows and 10,000 packets, at most 10 destination ports and at least 10 source ports.
BruteForce	At least 50 connections from one source to one target FTP port 21 or SSH port 22 during one minute.

These are development heuristics, not thresholds established by the cited literature. First-match rule priority applies. A rule hit indicates traffic that warrants review. FTP or SSH connections do not demonstrate failed credentials, and high traffic volume does not demonstrate an outage. No rule match must not be interpreted as Benign.

2 3 Grouping and evidence retention

A case joins consecutive alerts only when source file, rule type and ordered source and destination match, with no more than five minutes between alert-minute starts. BruteForce also requires the same target login port. Different sources or destinations are not merged merely because they share a target or scanner. Related cases may be linked without becoming one case.

The exported bundle retains up to six flow samples per alert, with source file and CSV row pointers. An optional local indexed database supports paginated inspection of the original flow records. The AI receives bounded samples and aggregates, not the entire raw archive. Labels, source filenames and analyst-only annotations are excluded from its tool view.

3 Agent Workflow

3 1 Case navigation

The current case workspace has five tabs: Overview, Timeline, AI check, Recommendations and Case record. Overview summarises the rule evidence. Timeline presents minute groups, linked alerts and sample records, with drill-down into records. AI check is started by the analyst. Recommendations presents proposed investigation steps. Case record presents a report and can save a summary snapshot after the required recommendation review.

3 2 Read only investigation tools

Tool	Evidence supplied
get_incident_details	Addresses, time window, case flow total and sample size.
get_related_alerts	Linked alert IDs and per-minute rule measurements; offset supports continuation.
get_network_flows	A bounded selection of sampled flow records with citable IDs.
get_incident_statistics	Case totals and explicitly separated sample-derived statistics.

The live model chooses tools through the backend allowlist. Every call is scoped to the active case. Unknown tools, invalid arguments and cross-case reads are rejected. The loop has configured limits of six model steps and twelve tool calls. A missing or failing live provider produces an unavailable or error state, rather than silently switching to a mock verdict.

3 3 Validation and disclosure limits

A proposal may say Likely Attack, Likely Benign or Needs Review. It must satisfy the output schema and evidence rules. The backend checks cited IDs against the active case and evidence actually returned to the model. Numeric claims must be supported by retrieved and canonical measurements. This does not prove the interpretation, causal claim or confidence is correct.

Each tool message retains the 8,000-character disclosure limit. Large arrays are reduced as complete JSON with an explicit omitted-record marker; alert pages can be continued. Omitted records do not enter the seen-evidence set. An oversized single record returns an error rather than broken JSON. Tool and validation outcomes are audited.

3 4 Timeline and ATT&CK

Timeline reconstruction is deterministic. All 1,106 current events resolve to case evidence and their stored order can be reproduced. PortScan may receive a tentative T1046 Network Service Discovery hint. Current DoS and BruteForce records remain Unmapped when flows cannot establish availability loss or credential guessing. MITRE defines those stronger behaviours in T1498 and T1110 [5-7]. The backend checks mapping compatibility and retrieved citations; a supported hint is not a confirmed attack.

4 Defensive Action

4 1 Investigation support

The agent proposes investigation actions such as reviewing related flows, checking alerts, reviewing the timeline or escalating to an analyst. Suggestions are linked to evidence. The intended defensive output is an explainable assessment and investigation plan; the AI does not block addresses, isolate devices, modify evidence, downgrade severity or close a case.

This restriction is structural: the AI tool registry exposes reads only. It aligns with OWASP guidance to limit functionality and authority and retain human control over consequential actions [8]. It reduces the range of possible effects but does not establish immunity to prompt injection or incorrect reasoning.

4 2 Safe closure and manual resolution

A Likely Benign proposal on PortScan, DoS or BruteForce requires explicit analyst confirmation before it can be treated as benign. Legacy DDoS is protected as well. Confirming such a proposal requires a written reason; rejecting an AI assessment also requires a reason. Neither AI confirmation nor recommendation approval automatically closes or downgrades the case.

The product supports a separate manual Resolve Case action after a case record has been saved. It requires the signed-in analyst, a reason of 10 to 1,000 characters and an exact true confirmation. The resolution is recorded in the audit trail. This human operation must not be described as autonomous AI remediation.

5 Human Approval

5 1 Review decisions and case notes

The current implementation asks the analyst to approve or reject every recommended check before saving the review. Approval places the step in the Home pending list. The analyst may later mark it complete. Approval and completion are separate records; neither proves that the investigation was performed correctly. A case-note draft becomes available only when at least one step has been approved.

The draft remains a draft. Case record can be read before formal saving, while saving its summary follows the existing review conditions. The report view distinguishes the saved summary from current supporting material. The competition does not mandate Home tasks or approval for each read-only inspection; simplifying those interactions is a usability improvement, not a completed feature [1].

5 2 Identity and audit

The local API uses a signed-in session and CSRF checks for writes. Recommendation approvals, notes, task completion, AI decisions and record operations bind the reviewer to the signed-in user. AI runs, tool calls, rejected outputs, analyst decisions, notes and resolution events enter a shared SQLite audit table with a hash chain. Update and delete triggers enforce append-only behaviour through normal database access. Individual recommendation decisions and their audit entries are transaction-linked; the whole workflow is not claimed to be one atomic transaction.

6 Results and Limitations

6 1 Historical development detection

The complete selected CIC-IDS2017 files were rescored, including groups that produced no alerts. Of 356,103 groups, 11 out-of-scope attack groups were excluded. The remaining in-scope attack total was 229 groups. The detector produced 156 true positives, 2 false positives from Benign and 73 false negatives. Binary precision was 98.73% and recall was 68.12%.

Rule	TP	FP	FN	Precision	Recall
PortScan	11	1	16	91.67%	40.74%
DoS	23	1	52	95.83%	30.67%
BruteForce	122	0	5	100.00%	96.06%

Of 355,863 Benign groups, 2 triggered rules: a false-positive rate of approximately 0.000562%, not zero. The exported nine cases include two cases whose grouped ground truth is purely Benign. Case grouping reconstruction passed, but evaluation of alert-bearing cases alone cannot establish case-level recall. These data informed development, so the numbers are not independent performance results.

6 2 External domain detection

CIDDS-001 OpenStack internal weeks 1 to 4 were evaluated separately [4]. The detector, adapter and archive hashes were frozen before scoring, and the acceptance rerun reproduced the stored external result. One unidirectional NetFlow row counts as one flow; the scoring unit remains source file, ordered address pair and minute. Ambiguous or out-of-scope groups are excluded; a Benign and single-target-attack mixture is scored as attack.

Rule	TP	FP	FN	Recall
PortScan	48	0	40,617	0.118%
DoS	56	0	80	41.176%
BruteForce	2	0	555	0.359%

The external test scored 5,942,316 groups and excluded 4,260 ambiguous or out-of-scope groups; 786 scored groups mixed Benign with one attack type. Recall is poor, especially for PortScan and BruteForce. Zero observed false positives alongside few positive predictions is not evidence of broadly reliable precision. The thresholds were not retuned against this frozen test.

6 3 Real AI investigations

Two separate sets were run with the real Codex provider. Each run used isolated state and audit files and left analyst decisions pending. No production decision was approved for the user. Both sets used the configured default model, temperature setting 0.0, six-step limit and twelve-tool limit. The default model alias does not pin an underlying version or guarantee deterministic answers.

Measure	Development smoke	External diagnostic
Cases and runs	5 cases and 5 runs	5 groups and 5 runs
Completed investigations	5 of 5	5 of 5
Likely Attack	2	0
Needs Review	3	5
Likely Benign	0	0
Evidence validation failures	0	0
Audit chains verified	5 of 5	5 of 5
Median tool calls	4	4
Median run time	42.69 seconds	39.39 seconds

The development smoke cases had already been inspected and test workflow behaviour only. The external diagnostic selected one group for each target attack and two normal groups from CIDDS week 1 by a fixed CSV-order rule, before model calls. Original labels were excluded from model inputs. Unmatched groups entered an isolated review queue; they were not counted as successful detector alerts.

All five external verdicts were Needs Review. Attack-to-Likely-Benign was 0/3 and Benign-to-Likely-Attack was 0/2, but abstention was 5/5. This is not 100% accuracy: the agent made no definite classification. There were only five purposively selected groups, with dataset labels and automated consistency checks rather than human expert adjudication. They share the CIDDS source with the detector test and cannot establish generalisable AI accuracy.

6 4 Software and safety verification

The final suite passed 254 tests with zero failures or skips, and the frontend production build passed. The suite covers rule and grouping boundaries, label withholding, tool scope, numeric and citation checks, bounded JSON continuation, safety denial, forged reviewer identities, manual resolution and append-only auditing. A separate synthetic safety contract evaluation passed 21/21 scenarios. These counts measure software contracts, not a 100% safety rate or analyst effectiveness.

6 5 Remaining limitations

Detector coverage is the main weakness. Many externally labelled attacks never trigger a rule and therefore never reach the normal AI workflow. Fixed minute boundaries can split bursts, count thresholds miss slow activity and first-match rule priority can mask simultaneous behaviours. Address-and-time grouping is practical correlation, not proof that records belong to one campaign.

Evidence is incomplete. Sample flows lack payload, authentication outcomes, asset importance and business context. Connection counts cannot prove password guessing, and packet volume cannot prove service failure. Source pointers support traceability but do not independently validate the original captures or labels. Timestamp timezone assumptions must not be strengthened beyond the source data.

AI validation is necessary but limited. A cited record and supported number do not establish the correctness of the conclusion. Confidence is model-reported rather than empirically calibrated. External abstention may be appropriate caution, but it also leaves the analyst with unresolved work. Small purposive samples, no expert adjudication and an unpinned model prevent strong accuracy or reproducibility claims.

Human review is also unmeasured. A recorded name, approval click or written reason is not evidence of a sound security decision. The recommendation approval and Home task sequence can duplicate work; it should be tested with analysts before deployment. The prototype has not demonstrated reduced investigation time, lower workload or improved analyst outcomes.

The audit chain is locally verifiable, not tamper-proof against a machine or database administrator who can replace the storage and application. Static historical JSON is bundled with the frontend. The single-user loopback demo and its authentication are not a production data-isolation boundary. Model-provider use also requires an appropriate evidence-sharing policy.

6 6 Next evaluation priorities

The next detector revision should separate training, calibration and test traffic before threshold selection and use fresh external data for later validation. A normal-only baseline, such as the separate experimental Isolation Forest code, should be compared at stated false-positive rates on disjoint blocks before any adoption. It is not the deployed detector and was not retrained in this acceptance round.

AI evaluation should expand to more externally sourced normal, attack and ambiguous cases, include expert review of a subset, pin the model version and measure both error and abstention. Authentication and availability evidence should be added before claiming stronger BruteForce or DoS conclusions. A user study should measure investigation time and decision quality rather than infer them from successful tool calls.

Conclusion

RiskPilot AI demonstrates a functioning SOC investigation workflow with traceable evidence, read-only AI tools, analyst control and auditable decisions. The acceptance results support those implementation claims. They also show that robust cross-domain detection and useful AI classification remain unproven. The prototype is suitable for demonstrating controlled investigation, with these limitations stated openly.

References

[1] HackAI. (2026). Agentic Cyber Defence challenge brief. GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon. https://hackai.my/tracks/cyber-defence

[2] Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. 31st USENIX Security Symposium, 2783-2800. https://www.usenix.org/conference/usenixsecurity22/presentation/alahmadi

[3] Canadian Institute for Cybersecurity. (n.d.). Intrusion detection evaluation dataset CIC-IDS2017. University of New Brunswick. https://www.unb.ca/cic/datasets/ids-2017.html

[4] Hochschule Coburg. (n.d.). CIDDS Coburg Intrusion Detection Data Sets. https://www.hs-coburg.de/forschen/cidds-coburg-intrusion-detection-data-sets/

[5] MITRE. (2026). Network Service Discovery T1046. MITRE ATT&CK. https://attack.mitre.org/techniques/T1046/

[6] MITRE. (2026). Brute Force T1110. MITRE ATT&CK. https://attack.mitre.org/techniques/T1110/

[7] MITRE. (2025). Network Denial of Service T1498. MITRE ATT&CK. https://attack.mitre.org/techniques/T1498/

[8] OWASP. (2025). LLM06 Excessive Agency. OWASP Gen AI Security Project. https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

Web references checked on 24 October 2026. Numerical results below are project measurements, not findings attributed to these external sources.

Project Evidence

The acceptance record is JOINT_ACCEPTANCE.md in the SOC-Triage repository. The following files under evaluation/ provide the underlying measurements and hashes.

Detection: detection-joint-20261024.json and cidds-joint-20261024.json.

Grouping and timeline: grouping-development-20261023.json and joint-contracts-20261024.json.

Live AI: live-joint-acceptance-20261024.json; cidds-ai-diagnostic-20261024/manifest.json and results.json.

Tests and safety: joint-tests-20261024.json and safety-joint-acceptance-20261024.json.